

Justificacion de Metodo de Autenticacion con dos Tokens - SIGEA

Ordoñez Silva, Yonel Jr.

Indice

I. Access Token	1
1.1. Ventajas	1
II. Refresh Token	2
2.1. Ventajas del Refresh Token:	2
III. Comparacion	2
IV. ¿Por qué es malo usar solo un token de acceso?	2
V. PRO TIP	3

¿Por qué es bueno usar dos tokens Access Token + Refresh Token?

Esta arquitectura es la estándar en sistemas modernos (Google, Facebook, AWS, Stripe, etc.).

I. Access Token

- Duración corta (ej. 15 minutos)
- Se envía en cada request
- Firmado y autosuficiente (JWT)

1.1. Ventajas

- Si alguien roba este token, solo tiene poder por pocos minutos.
- No necesitas acceder a la BD en cada request.
- Muy rápido y escalable.

II. Refresh Token

- Duración larga (ej. 1 hora – 7 días)
- No se envía en cada request → solo para renovar
- Se almacena en BD o Redis
- No es un JWT → es una string aleatoria

2.1. Ventajas del Refresh Token:

- Puedes invalidarlo en BD (= cerrar sesión real)
- Es seguro porque no viaja por la red salvo en /refresh
- Permite sesiones largas sin re-logins
- Permite rotación (“refresh token rotation”)
- Detiene ataques de robo de tokens

III. Comparacion

Criterio	Solo Access Token	Access + Refresh
Expiración	Debe ser larga (inseguro) o muy corta (molesto)	Acceso corto seguro + refresco cómodo
Logout	NO se puede invalidar un JWT sin blacklist	Puedes invalidarlo borrando el refresh token
Escalabilidad	Excelente	Excelente
Seguridad	Media	Muy alta
Usuario final	Debe iniciar sesión más seguido	Ni siente las renovaciones

IV. ¿Por qué es malo usar solo un token de acceso?

Porque:

- Si dura poco → rompe UX
- Si dura mucho → es inseguro
- No puedes invalidarlo → queda vivo hasta expirar
- Si quieres sesión larga → necesitas refresh
- No puedes hacer rotación → mala práctica

V. PRO TIP

El flujo ideal es:

- Access Token (15 minutos)
- Refresh Token (1 hora o 7 días)
- Renueva automáticamente si faltan 2 minutos
- Token viejo → se invalida en blacklist
- Cliente usa siempre el token más fresco
- Si el refresh se borra → sesión terminada
- Esto es exactamente como funcionan bancos, plataformas grandes y cualquier app segura.